

NETWORK SECURITY

Docente: Mg. Ing. Adolfo Cáceres Luque



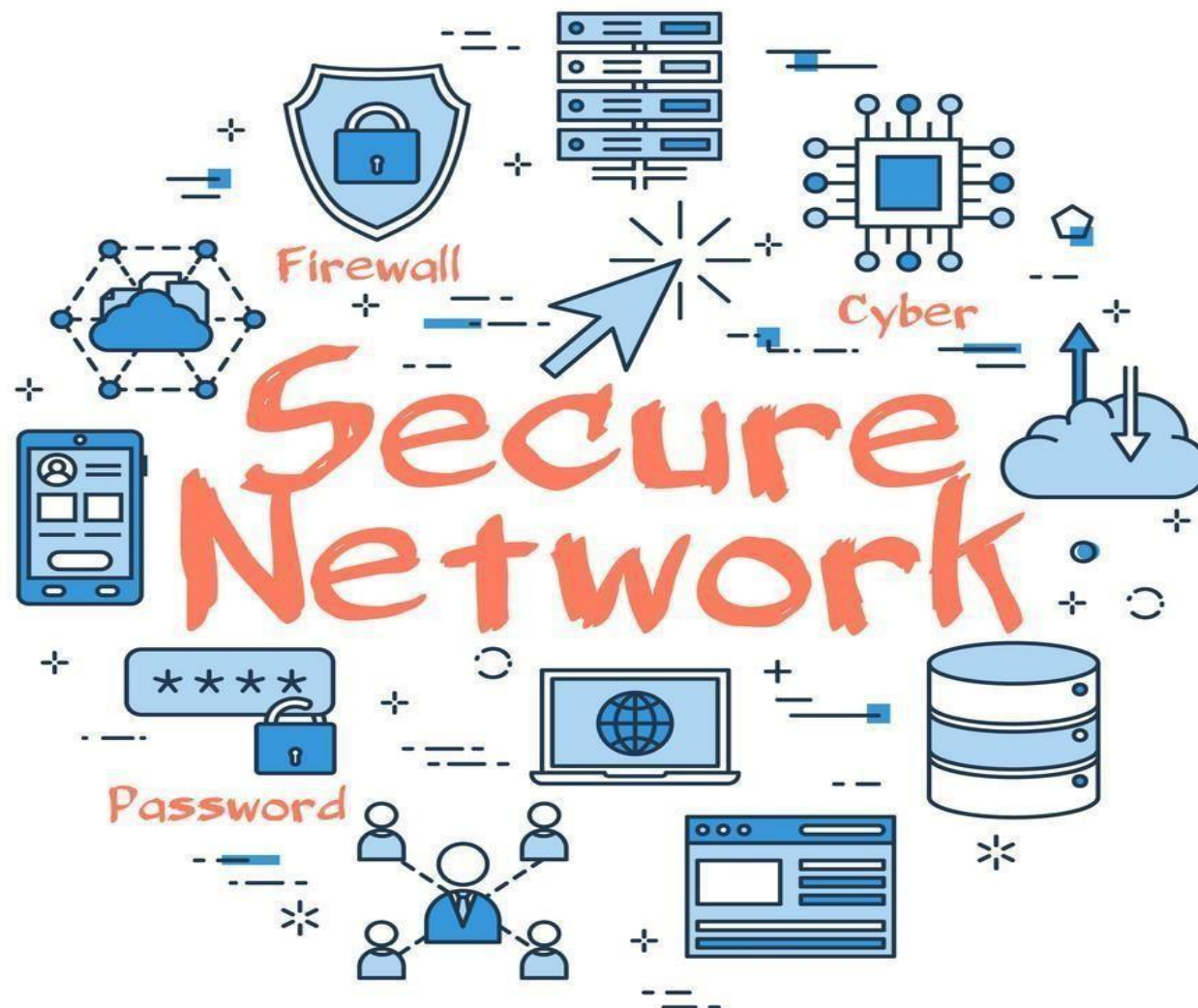
Universidad
Tecnológica
del Perú

Introducción al Network Security

Unidad 1 – Semana 2



Universidad
Tecnológica
del Perú



Logro de la sesión



- ✓ Al finalizar la sesión el estudiante tendrá los conceptos básicos de botnets , como se propaga y los objetivos en una red LAN.

Temas a tratar

1. Introducción a Botnets , objetivos y medios de propagación.
2. Servidor de comando y control.

¿Qué es un botnet?

- ✓ Un botnet está formado por un conjunto, generalmente elevado, de dispositivos conectados a Internet que han sido infectados con malware y que reciben órdenes de forma remota por parte de los ciberdelincuentes.
- ✓ Los dispositivos infectados que forman parte de una botnet también se conocen como bots o zombis.
- ✓ Cualquier equipo que tenga conexión a Internet como ordenadores, servidores, Routers, dispositivos IoT, etc., puede infectarse y llegar a formar parte de una botnet.
- ✓ Las diferentes tareas que realizan los equipos infectados son dirigidas generalmente desde un servidor central también conocido como **C&C** (por sus siglas en inglés Command & Control).
- ✓ Existe otra variedad denominada botnets P2P que carecen de ese único servidor C&C debido a la descentralización que proporcionan las redes P2P.

¿Cuál es el objetivo de un botnet?

Este tipo de red generalmente tiene como último fin el beneficio económico de los ciberdelincuentes que la han creado.

Para lograrlo pueden utilizar la botnet de diferentes maneras:

1.- Ataques de denegación de servicio distribuido o DDoS.

- ✓ En este tipo de ataques, el objetivo de los ciberdelincuentes es impedir el correcto funcionamiento de un servicio, como puede ser la página web de una organización con el consiguiente daño de su imagen y reputación.
- ✓ Para conseguirlo ordenan a un gran número de dispositivos zombis que accedan a la vez al mismo servicio, haciendo que este se sature llegando incluso a bloquearse e impidiendo que los usuarios puedan utilizarlo.

¿Cuál es el objetivo de un botnet?

2.- Envío de spam.

- ✓ Los ciberdelincuentes utilizan los equipos infectados para enviar correos electrónicos fraudulentos de forma masiva, que en muchos casos incluyen estafas como enlaces a páginas web de tipo phishing o malware.

3.- Fraudes publicitarios.

- ✓ Normalmente, los servicios de anuncios en Internet pagan a los administradores de las webs donde figuran en función de varios factores, entre los que se incluye la visualización del anuncio y el hacer clic en el mismo.
- ✓ Los ciberdelincuentes ordenan a los bots que visiten sus propios sitios web y hagan clic en los anuncios para generar beneficios económicos de manera fraudulenta.

¿Cuál es el objetivo de un botnet?

4.- Venta y alquiler de la botnet.

- ✓ Las botnet en algunos casos son alquiladas por usuarios que desean realizar algún tipo de actividad delictiva, como perpetrar ataques de denegación de servicio.
- ✓ También pueden ser vendidas en porciones para que los nuevos administradores hagan con ella a través de los dispositivos infectados, cualquier tipo de actividad fraudulenta.

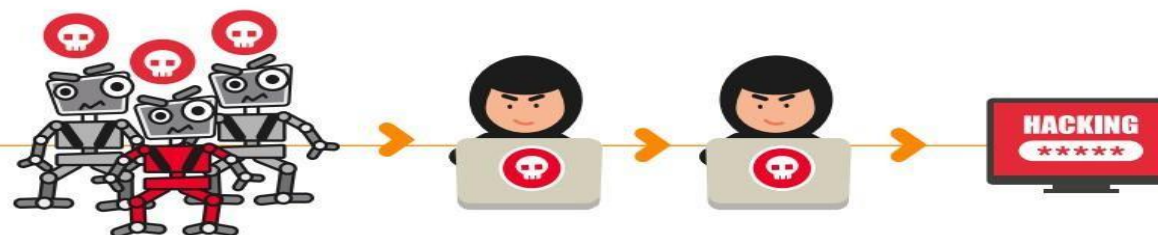
5.- Robo de información.

- ✓ La información personal como pueden ser las credenciales de acceso o datos bancarios, es valiosa en sí misma, por ello los ciberdelincuentes intentan conseguirla mediante campañas de phishing lanzadas desde botnets para posteriormente venderla al mejor postor.

Botnets

¿Cómo funciona?

Así se conoce a la **red compuesta por diversos dispositivos infectados y controlados de forma remota por uno o varios ciberdelincuentes.**



¿Cómo se propaga/infecta/extiende?

Para infectar un equipo, los atacantes suelen recurrir a códigos maliciosos en páginas webs tras explotar una vulnerabilidad. Una vez que accedemos a la web, nuestro equipo queda infectado sin ser consciente de ello. También suelen recurrir al envío de archivos maliciosos a través de mensajes por Internet, como el correo electrónico.

¿Cuál es su objetivo?

El atacante busca controlar el mayor número de dispositivos posibles con los que llevar a cabo sus actividades ilícitas con la mayor probabilidad de éxito posible.

¿Cómo puedes evitar que un dispositivo forme parte de una botnet?

- ✓ Para los ciberdelincuentes, son un negocio muy rentable y cuantos más dispositivos consigan infectar, más lo será.
- ✓ Para prevenir su infección la primera línea de defensa es evitar situaciones que puedan comprometer la seguridad de los dispositivos.
- ✓ Las botnets se difunden principalmente por medio de campañas de malware, vulnerabilidades no parcheadas o configuraciones poco robustas.

¿Cómo puedes evitar que un dispositivo forme parte de una botnet?

Para prevenir ser parte de una botnet es recomendable seguir los siguientes pasos:

1. Mantener actualizado tanto el sistema operativo, como las herramientas de seguridad que tengan instaladas todos los dispositivos.
2. Utilizar soluciones antimalware.
3. Precaución a la hora de abrir documentos adjuntos en correos electrónicos o enlaces a sitios web.
4. Utilizar siempre software original y descargarlo de su fuente legítima.
5. Comprobar las configuraciones de seguridad que tienen los dispositivos, sobre todo los que forman parte del IoT, modificando las credenciales de acceso por unas robustas.
6. Los Routers o cortafuegos también pueden formar parte de una botnet, por lo que es importante cambiar todas las contraseñas por defecto por otras robustas, deshabilitar cualquier servicio innecesario y mantener el sistema actualizado.
7. Concienciar a los empleados sobre el uso seguro de los equipos.

Servicio AntiBotnet

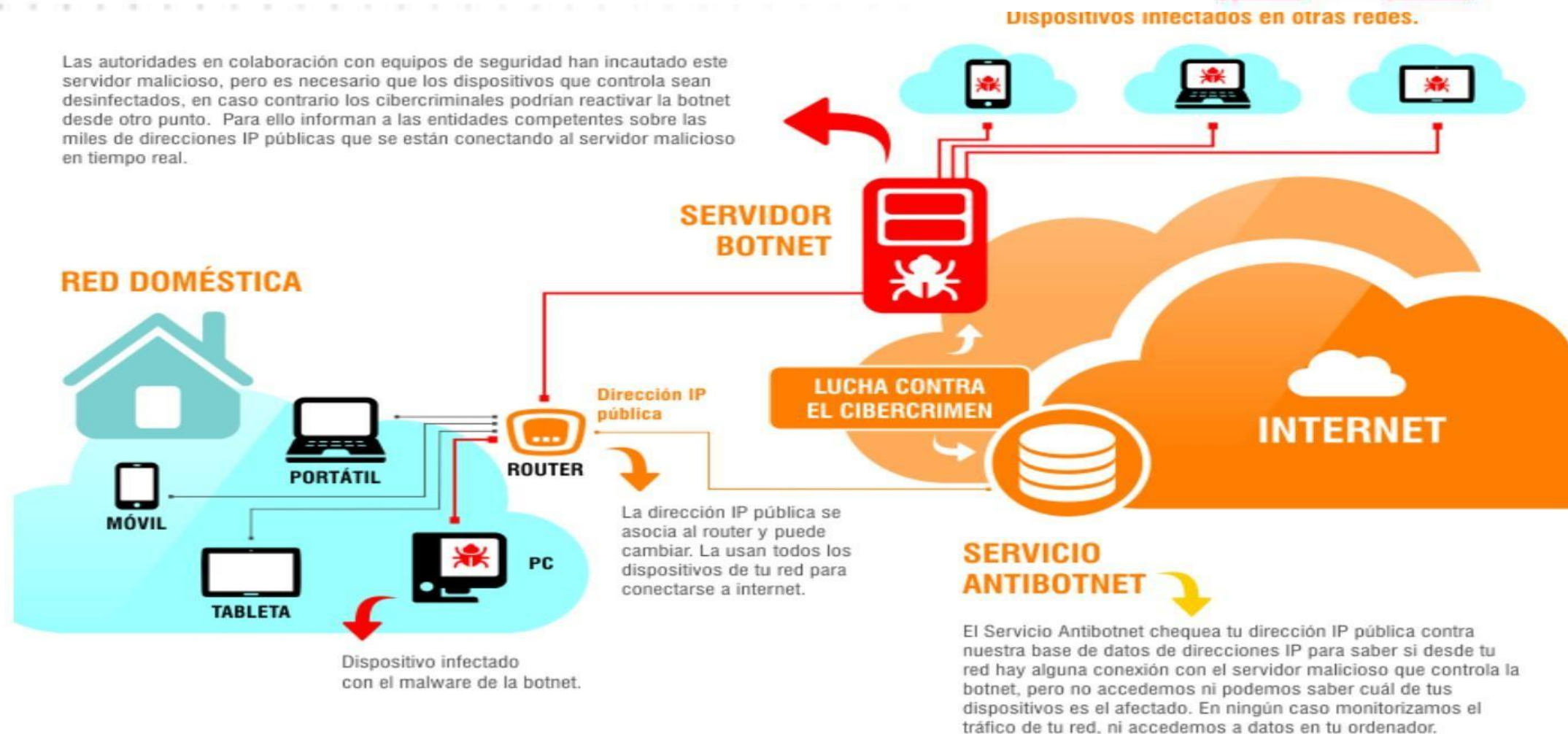
- ✓ El Servicio AntiBotnet es un mecanismo que te permite conocer si existen amenazas o incidentes de ciberseguridad relacionados con redes de ordenadores comprometidos o botnets, u otras amenazas asociadas a tu conexión a Internet.
- ✓ Para ello se chequea tu dirección IP pública contra una base de datos de direcciones IP maliciosas o consideradas dentro de actividades botnet.

Servicio AntiBotnet (España)

¿Qué es la dirección IP pública y por qué se utiliza para saber si estoy afectado?

- ✓ La dirección IP pública es la dirección que identifica a los dispositivos de nuestra red cuando navegamos por Internet y que normalmente está asociada al Router que proporciona la conexión.
- ✓ Esta dirección es asignada por nuestro operador de servicios de Internet y puede ser fija (siempre tenemos la misma) o dinámica, es decir, puede cambiar a lo largo del tiempo, siendo esto algo transparente para el usuario final.
- ✓ Decimos que es pública, porque al navegar por Internet este dato es conocido o proporcionado a aquellos sitios o servicios que utilizemos, visitemos o por los que naveguemos.
- ✓ Según esto, si algún ordenador o dispositivo de tu red está infectado por una botnet u otra amenaza, el equipo servidor desde el que se esté controlando dicha red maliciosa en este momento asociará tu ordenador con dicha dirección IP.

Las autoridades en colaboración con equipos de seguridad han incautado este servidor malicioso, pero es necesario que los dispositivos que controla sean desinfectados, en caso contrario los cibercriminales podrían reactivar la botnet desde otro punto. Para ello informan a las entidades competentes sobre las miles de direcciones IP públicas que se están conectando al servidor malicioso en tiempo real.



¿Ante un ataque con botnets que se puede hacer?

- ✓ Desactivar inmediatamente de la red el equipo o servicio vulnerable, si es posible.
- ✓ Realizar una copia cifrada de los ficheros logs (ficheros de registro) de los servidores para aportarlos como prueba en caso de denuncia.

Preventivamente y antes de restablecer el servicio:

- ✓ Realizar una auditoria de seguridad para detectar errores de configuración y vulnerabilidades que pongan en peligro la red.
- ✓ Configurar correctamente el servidor DNS para permitir el acceso únicamente desde la red interna.
- ✓ Configurar el cortafuegos para separar los servicios internos de los externos, filtrando el tráfico de red.

Lecciones aprendidas

- ✓ Es importante estar preparado por si ocurre un incidente, es decir tener un procedimiento de gestión de incidencias que todo el mundo conozca para saber cómo actuar.
- ✓ Utilizar un servicio externo o personal especializado en ciberseguridad para el diseño y mantenimiento de la red y de los servidores de la empresa.
- ✓ Realizar auditorías de seguridad periódicas para aseguramos que los servicios web están bien configurados y que no tienen vulnerabilidades.
- ✓ Disponer de una política de copias de seguridad que incluya los logs de los sistemas y redes. Hay que hacerlas regularmente, conservarlas en un lugar externo y separado (no conectado) y probar que funcionan .
- ✓ Tener a mano la lista de contactos de apoyo y de denuncia para estos casos.
- ✓ Utilizar el servicio AntiBotnet para averiguar si nuestros equipos forman parte de alguna botnet.

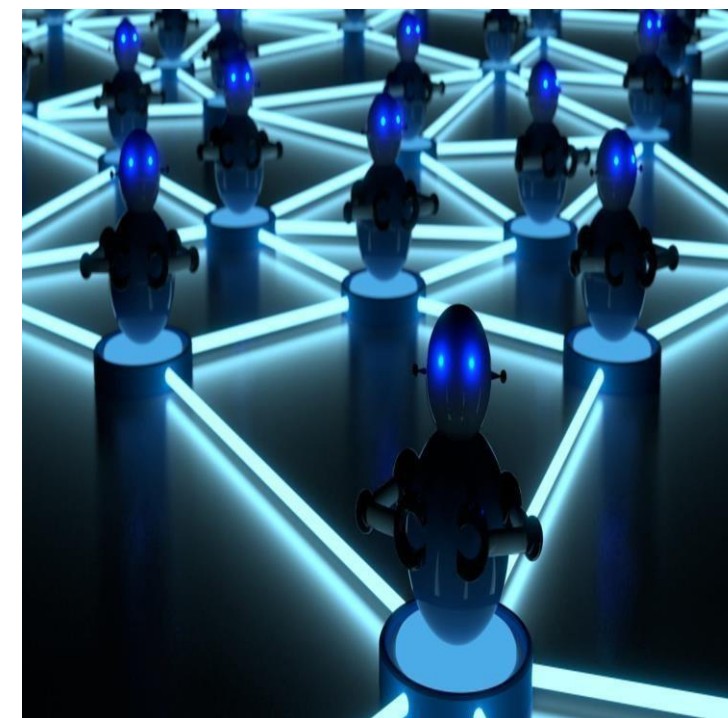
SERVIDORES DE COMANDO Y CONTROL

Servidor de comando y control (C&C)

- ✓ La infraestructura de comando y control es el conjunto de herramientas y técnicas que utilizan los atacantes para mantener la comunicación con los dispositivos comprometidos tras la explotación inicial.
- ✓ Los mecanismos específicos varían mucho entre ataques, pero C2 generalmente consta de uno o más canales de comunicación encubiertos entre dispositivos en una organización objetivo y una plataforma que controla el atacante.
- ✓ Estos canales de comunicación se utilizan para enviar instrucciones a los dispositivos comprometidos, descargar herramientas maliciosas adicionales, canalizar los datos robados o utilizar los dispositivos infectados como zombies.
- ✓ Una estrategia común para canalizar la comunicación es mezclarse con otros tipos de tráfico legítimo que puedan estar en uso en la organización objetivo, como HTTP/HTTPS o DNS.

Servidor de comando y control (C&C)

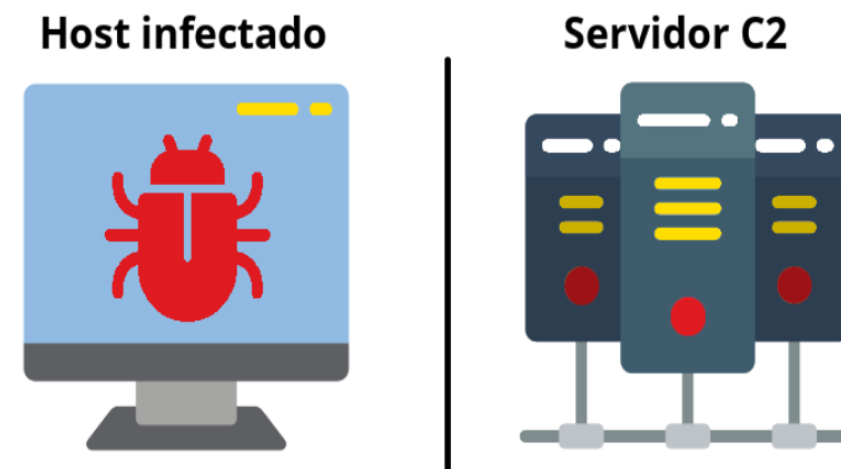
- ✓ Un importante problema de la ciberseguridad actual consiste en que un equipo lícito de una red se pueda convertir en un arma para ataques dirigidos por ciberdelincuentes, tanto a través de una botnet, como las denominadas Amenazas Persistentes Avanzadas (APT).
- ✓ En el caso de botnets, los servidores de C&C sirven como infraestructura principal para las máquinas comprometidas en una red de bots. Pueden utilizarse para difundir comandos que pueden robar datos, propagar malware, interrumpir servicios web, etc.
- ✓ En el caso de los ataques APT, se dirigen a organizaciones o individuos y tienen como objetivo establecer una presencia continua y no detectada en la infraestructura objetivo. La finalidad de estos ataques suele ser el espionaje, acceso a datos, propiedad intelectual, documentos confidenciales, etc.



¿Cómo funcionan los servidores de mando y control (C2)?

Paso 1

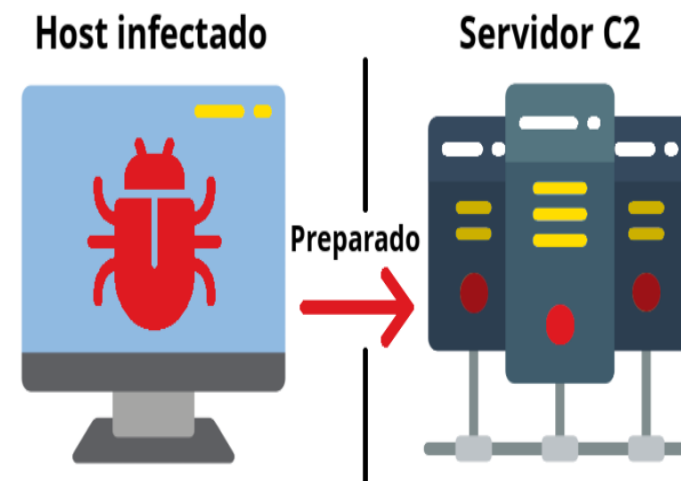
- ✓ El atacante infecta el sistema de un usuario o un sistema dentro de una organización con malware aun estando éstos protegidos.
- ✓ Esto puede hacerse utilizando diferentes métodos como correos electrónicos de phishing, publicidad maliciosa (adware), plugins de navegador vulnerables, instalación directa de software malicioso a través de una memoria USB o unidad de disco, etc.



¿Cómo funcionan los servidores de mando y control (C2)?

Paso 2

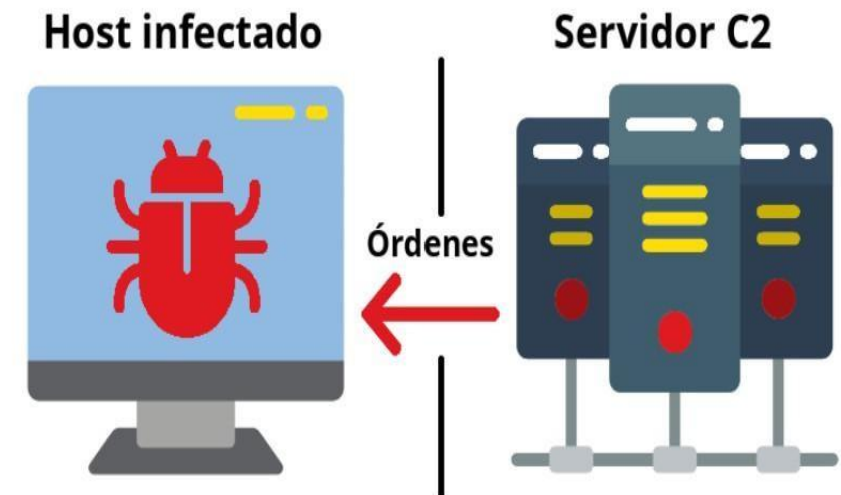
- ✓ Una vez que el host está infectado, se establece la comunicación con el servidor C2 y el sistema comprometido envía un acuse de recibo al servidor C2 para indicar que está listo para recibir comandos.
- ✓ Esta comunicación se realiza principalmente a través de tráfico de confianza como el DNS.



¿Cómo funcionan los servidores de mando y control (C2)?

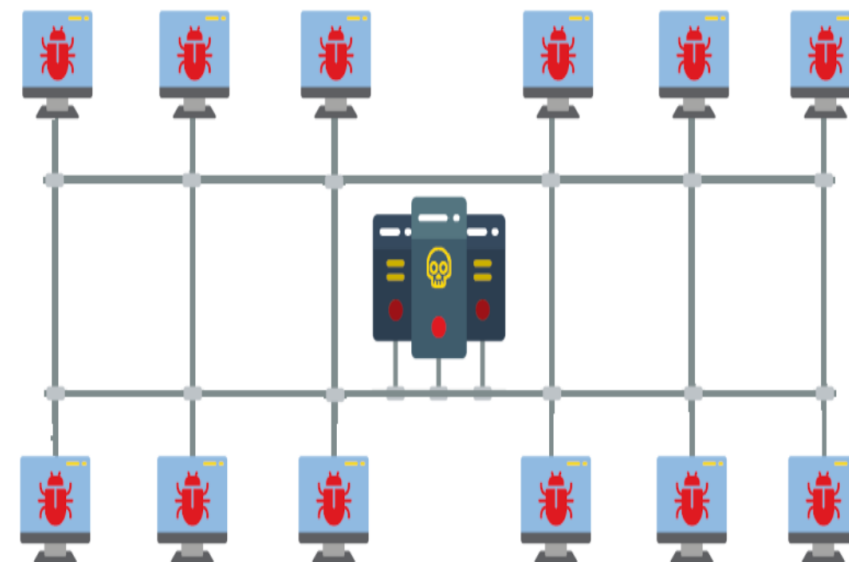
Paso 3

- ✓ Con el canal C2 establecido, el sistema infectado puede ahora recibir más comandos del servidor C2 mientras el malware no sea detectado.
- ✓ El servidor de Comando y Control puede utilizar este canal para enviar más software malicioso a instalar, cifrar datos e incluso extraer recursivamente datos del host infectado.



¿Cómo funcionan los servidores de mando y control (C2)?

- ✓ El servidor C2 también puede emitir órdenes al host infectado para que empiece a buscar vulnerabilidades en otros sistemas de la red con el fin de pivotar por la red.
- ✓ Esto puede comprometer completamente toda la infraestructura informática de una organización y llevar a la ampliación de equipos comprometidos aumentando el tamaño de la botnet.
- ✓ El único propósito de toda esta organización de máquinas zombies es recibir órdenes del servidor de mando y control para realizar ataques coordinados.



Conclusiones



1. Mantener activos y actualizados los programas de protección, como el antivirus y el firewall, así como mantener nuestro sistema actualizado para evitar vulnerabilidades.
2. Es recomendable evitar la descarga de archivos maliciosos y la utilización de contraseñas robustas.
3. Revisar los dispositivos IoT que se encuentren actualizados o desactivados de internet.
4. La infraestructura de comando y control es el conjunto de herramientas y técnicas que utilizan los atacantes para mantener la comunicación con los dispositivos comprometidos tras la explotación inicial.

Gracias!

Desaprende lo que te limita



**Universidad
Tecnológica
del Perú**